

TPE – Pre-entrega

72.20 Redes de Información

Acceso Remoto Seguro con WireGuard

Client-To-Site y Site-To-Site

Integrantes:

Jose Burgos (61525)

Pedro Curti (61616)

20 Abril 2026

1 Problemática y Contexto

The Store es una plataforma de e-commerce con arquitectura de microservicios sobre Kubernetes (Kind), compuesta por cinco servicios: UI (Java), Catalog (Go), Cart (Java), Orders (Java) y Checkout (Node.js). Todos se comunican vía HTTP plano a través de ClusterIP, con un Ingress NGINX expuesto únicamente en puerto 80 sin TLS.

1.1 Pains identificados

- P1: Comunicación sin cifrado:** Credenciales de BD (Secrets en Base64) transitan en texto plano.
- P2: Sin Network Policies:** Cualquier pod puede comunicarse con cualquier otro (movimiento lateral sin restricciones).
- P3: Ingress sin TLS:** Datos sensibles (pagos, órdenes) viajan sin cifrar entre cliente y frontend.
- P4: Acceso administrativo desprotegido:** `kubectl` y `docker` se usan directamente sobre red local, sin túnel seguro.
- P5: Puertos internos expuestos al host:** Redis (6379), Checkout (8085) accesibles sin autenticación desde la red local.
- P6: Sin Zero Trust:** Confianza total dentro del cluster, sin mTLS ni verificación de identidad.
- P7: Acceso remoto inexistente:** No hay mecanismo para acceder al cluster fuera de la red local.
- P8: CI/CD sin canal dedicado:** GitHub Actions accede al cluster sin VPN ni túnel cifrado.

2 Diseño de la Solución

2.1 Enfoque: dos escenarios VPN con WireGuard

Se proponen **dos escenarios complementarios** que abordan los pains de acceso remoto:

- **Client-To-Site (acceso administrativo remoto):** Administradores y desarrolladores se conectan al cluster desde fuera de la red local mediante un cliente WireGuard.
- **Site-To-Site (red corporativa ↔ cluster):** Túnel permanente que permite a cualquier empleado en la red corporativa acceder a los servicios del cluster **sin instalar cliente VPN**.

2.2 Escenario 1: Client-To-Site (Acceso administrativo remoto)

2.2.1. Componentes

- **Gateway VPN Pod:** Pod dedicado en `vpn-system` con interfaz `wg1` en subred `10.200.0.0/24`. Expuesto via `NodePort`.
- **Clientes admin:** Laptops con WireGuard nativo, cada una con su par de claves propio.
- **AllowedIPs por admin:** Define qué subredes del cluster puede alcanzar cada administrador (principio de mínimo privilegio).

2.2.2. Flujo

El admin ejecuta `wg-quick up wg0` → handshake Noise IK (1 RTT) → túnel establecido → accede via `kubectl` a la API Server y a servicios internos. Todo el tráfico viaja cifrado con ChaCha20-Poly1305.

2.2.3. Gestión de claves

Cada admin genera su par de claves localmente. La clave pública se agrega como peer en el gateway. La privada nunca sale del equipo del admin. Rotación: generar nuevas claves, actualizar peer en el gateway, reconectar.

2.3 Escenario 2: Site-To-Site (Red corporativa ↔ Cluster)

2.3.1. Contexto

La empresa tiene su red corporativa (`172.20.0.0/24`) y necesita que todos sus empleados consuman los servicios de The Store sin acceso a la red local del cluster ni software VPN en cada PC.

2.3.2. Componentes

- **Gateway Corporativo (Peer A):** Contenedor Docker con WG, IP `172.20.0.1` en red corporativa, `10.100.0.1` en el túnel.
- **Gateway del Cluster (Peer B):** Pod WG con IP `10.100.0.2` en el túnel (`wg0`, subred `10.100.0.0/30`), capacidad de enrutar a pods (`10.244.0.0/16`) y services (`10.96.0.0/12`).
- **Ruteo corporativo:** PCs con ruta estática hacia el cluster via Gateway Corporativo (distribuible por DHCP).
- **IP forwarding + NAT:** Ambos gateways con `ip_forward` y reglas iptables.

2.3.3. AllowedIPs — clave del Site-To-Site

Solo el tráfico que coincide con AllowedIPs cruza el túnel. Todo lo demás sigue su ruta normal.

2.3.4. Flujo

Empleado en 172.20.0.50 accede a `http://<IP-service>` → ruta estática lo dirige al Gateway Corporativo → AllowedIPs coincide → paquete cifrado por túnel → Gateway del Cluster descifra y forwarda al Service K8s → respuesta inversa. **El empleado no tiene WireGuard instalado.**

2.3.5. Gestión de claves

Solo **2 pares de claves** (uno por gateway). Rotación directa: generar claves nuevas en un gateway, actualizar peer remoto, reiniciar interfaz.

2.4 Segmentación interna: Kubernetes Network Policies

Como complemento, se implementan Network Policies nativas sin modificar los pods de aplicación:

- **Default deny:** Todo tráfico no explícitamente permitido es denegado.
- **Política por servicio:** UI puede hablar con Catalog, Cart, Orders, Checkout. Orders solo acepta de UI y Checkout. Catalog solo acepta de UI y del túnel Site-To-Site.
- Movimiento lateral bloqueado a nivel de red K8s, sin sidecars ni dependencia de IPs de pods.

2.5 Alternativas evaluadas

Criterio	OpenVPN	WireGuard	IPSec
Capa	Userspace	Kernel	Kernel
Handshake	TLS (pesado)	Noise IK (1 RTT)	IKEv2 (múltiples RTT)
Claves	PKI X.509	Pre-compartidas	PKI X.509
Site-To-Site	Hub-and-spoke	Nativo (AllowedIPs)	Hub-and-spoke
Complejidad	Alta	Baja	Muy alta

Cuadro 1: Tecnología seleccionada

Decisión: WireGuard por simplicidad (archivos de texto), rendimiento kernel-space, handshake rápido y AllowedIPs nativo para ambos escenarios sin PKI.

2.6 Scope del POC

Incluye: Gateway VPN pod (Client-To-Site + Site-To-Site), simulación de red corporativa con Docker, túneles funcionales, AllowedIPs restrictivos, Network Policies, rotación de claves, validación de tráfico cifrado.

No incluye: PKI enterprise, Vault/HSM, Service Mesh, despliegue productivo cloud, OIDC/SAML, HA de gateways, monitoreo de túneles.

2.7 Casos de uso

CU-1 — Admin accede remotamente (Client-To-Site): Admin ejecuta `wg-quick up wg0` → se conecta al gateway del cluster → usa `kubectl` y accede a servicios internos. Solo alcanza subredes en sus AllowedIPs.

CU-2 — Empleado accede sin VPN cliente (Site-To-Site): Empleado en red corporativa abre el navegador hacia un servicio del cluster → tráfico cruza el túnel de forma transparente → no requiere software VPN en su PC.

CU-3 — Segmentación por AllowedIPs: Admin con AllowedIPs limitado no puede alcanzar pods directos. PC corporativo no envía tráfico no-cluster por el túnel. Solo tráfico explícitamente definido cruza.

CU-4 — Rotación de claves ante compromiso sospechado: Un administrador detecta actividad inusual en su túnel y decide rotar sus credenciales. Genera un nuevo par de claves en su laptop con `wg genkey`. Envía únicamente la clave pública al operador del cluster, quien actualiza el peer correspondiente en el Secret del gateway y reinicia el pod. El admin reconecta con `wg-quick down wg0 && wg-quick up wg0` y el túnel se restablece con las nuevas claves. Las claves anteriores quedan invalidadas inmediatamente. El mismo procedimiento aplica para Site-To-Site, pero involucra solo 2 pares de claves en lugar de $N \times (N-1)$, lo que hace la rotación rápida y error-proof.

3 Diagrama de Arquitectura

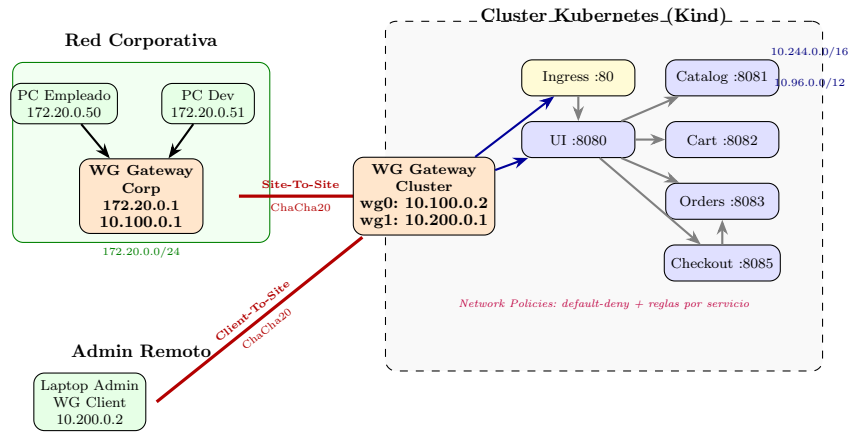


Figura 1: Arquitectura: Client-To-Site + Site-To-Site con WireGuard